[Año]

Fundamentos de ciberseguridad

TEMA 1 EJERCICIO 1.1

YOLANDA RODRÍGUEZ MORENO

ÍNDICE:

TEMA 1: FUNDAMENTOS DE CIBERSEGURIDAD 1
EJERCICIO 1.1 GLOSARIO 2
1.Amenazas y vulnerabilidades informáticas. 2
2.Medidas de protección básicas. 4
3. Análisis de los incidentes de seguridad. 5
4. Herramientas y tecnologías de aplicación. 6
5. Normativa y buenas prácticas de uso. 7

TEMA 1: FUNDAMENTOS DE CIBERSEGURIDAD

EJERCICIO 1.1 GLOSARIO

1.Amenazas y vulnerabilidades informáticas.

Una amenaza es algo que puede provocar un daño en un sistema informático, mientras que una vulnerabilidad es una debilidad que puede ser aprovechada para conseguirlo.

INCIBE – Amenaza vs. vulnerabilidad: cómo diferenciarlos

En seguridad informática estos dos conceptos están muy relacionados, pero no significan lo mismo. Una amenaza representa un posible peligro, mientras que una vulnerabilidad es el punto débil que puede facilitar que ese peligro llegue a producirse.Las amenazas pueden ser **activas**, cuando intentan modificar, destruir o alterar información o sistemas, o **pasivas**, cuando buscan obtener información sin modificar directamente el sistema.

También podemos valorar las consecuencias de un ataque teniendo en cuenta tres principios básicos:

- **Confidencialidad:** la información solo debe estar disponible para las personas autorizadas.
- **Integridad:** los datos deben mantenerse correctos y no modificarse sin permiso.
- **Disponibilidad:** los sistemas y la información deben poder utilizarse cuando sean necesarios.

Estos tres principios forman una base importante de la seguridad de la información.

Principales conceptos

Amenaza: situación, acción o elemento que puede causar daños en un sistema, en sus datos o en sus usuarios.

Vulnerabilidad: debilidad o fallo de un sistema que puede ser aprovechado para comprometer su seguridad.

Confidencialidad: intenta evitar que personas no autorizadas puedan acceder a una información.

Integridad: busca que la información no sea modificada, eliminada o alterada sin autorización.

Disponibilidad: garantiza que los sistemas y los datos puedan utilizarse cuando los usuarios autorizados los necesiten.

Malware: software creado para realizar acciones perjudiciales o no autorizadas. Dentro de este grupo encontramos virus, troyanos, gusanos, spyware y ransomware, entre otros.

Ingeniería social: utiliza el engaño o la manipulación de las personas para conseguir información, acceso o alguna acción que beneficie al atacante. Muchas veces el objetivo no es atacar directamente al sistema, sino conseguir que la propia persona facilite la entrada.

DoS: ataque que intenta dejar un servicio o sistema sin funcionar mediante una gran cantidad de peticiones o utilizando sus recursos hasta saturarlos.

DDoS: es parecido al DoS, pero las peticiones proceden de muchos dispositivos al mismo tiempo, lo que hace que el ataque sea más difícil de controlar.

Man-in-the-middle (MITM): ataque en el que una persona consigue colocarse entre dos partes que se están comunicando para interceptar o incluso modificar la información que intercambian.

Exploit: código, programa o técnica que aprovecha una vulnerabilidad concreta para realizar una acción que normalmente no debería ser posible.

Inyección SQL: ataque que aprovecha una aplicación que no controla correctamente los datos introducidos por el usuario para manipular consultas SQL y acceder, modificar o eliminar información de una base de datos. INCIBE sigue registrando vulnerabilidades de este tipo en aplicaciones actuales.

Cross-Site Scripting (XSS): vulnerabilidad que permite introducir código, normalmente JavaScript, en una página web para que pueda ejecutarse en el navegador de otros usuarios.

Cifrar: transformar la información para que no pueda ser entendida por cualquiera que acceda a ella. Para recuperar la información original es necesario descifrarla mediante el procedimiento o clave correspondiente.

Ransomware: tipo de malware que bloquea el acceso a un equipo o cifra sus archivos y después pide un rescate para intentar recuperar el acceso.

Fuentes

INCIBE – Glosario de ciberseguridad

INCIBE – Medidas de prevención contra ataques DoS y DDoS

INCIBE – Guía sobre ransomware

.

2.Medidas de protección básicas.

Las medidas de protección son mecanismos que ayudan a controlar quién puede acceder a un sistema, qué puede hacer y qué comunicaciones están permitidas.

Para proteger un sistema no basta con instalar un antivirus. Hay que controlar los accesos, revisar el tráfico de red, observar lo que ocurre y comprobar periódicamente si existen problemas de seguridad.

Algunas medidas básicas son las siguientes:

Autenticación multifactor (MFA): método que utiliza dos o más formas diferentes para comprobar que una persona es realmente quien dice ser. Por ejemplo, una contraseña y un código recibido en el móvil.

Rol: función que tiene un usuario dentro de un sistema y que determina qué acciones puede realizar.

Permiso: autorización concreta que indica qué puede hacer un usuario o un rol, como leer, modificar, crear o eliminar información.

Reglas: condiciones que indican qué acciones están permitidas y cuáles deben bloquearse.

Filtrado: revisión del tráfico o de la información para dejar pasar lo permitido y bloquear aquello que no cumple las reglas.

Puerto: número que permite identificar un servicio o aplicación concreta dentro de una conexión de red. Ayuda a dirigir los datos hacia el programa correspondiente.

Protocolo: conjunto de reglas que permite que diferentes dispositivos se comuniquen siguiendo una forma determinada.

Router: dispositivo que dirige los datos entre diferentes redes para que lleguen al destino correspondiente.

Monitorear: observar de forma continua un sistema o una red para detectar comportamientos extraños, fallos o posibles amenazas.

Auditoría: revisión de un sistema y de sus medidas de seguridad para detectar problemas, vulnerabilidades y posibles mejoras.

El control de accesos y la gestión de riesgos son también elementos importantes dentro de la seguridad de los sistemas. El ENS, por ejemplo, incluye expresamente la autorización y control de los accesos y el principio de mínimo privilegio.

Fuentes

INCIBE – Instituto Nacional de Ciberseguridad

CCN – Centro Criptológico Nacional, guías de seguridad

3. Análisis de los incidentes de seguridad.

Un **incidente de seguridad** es un suceso que afecta o puede afectar a la seguridad de un sistema, una red o la información que contiene. Para solucionarlo se sigue un proceso que permite detectarlo, analizarlo, contenerlo, eliminar la causa y recuperar el funcionamiento normal.

Cuando ocurre un incidente no se trata simplemente de solucionar el problema y seguir trabajando. Primero hay que saber qué ha pasado, hasta dónde ha llegado y qué elementos pueden haberse visto afectados.

El ciclo de actuación puede dividirse en varias fases:

Detección: se identifica que puede estar ocurriendo un problema de seguridad.

Análisis: se estudia lo sucedido para averiguar cómo comenzó, qué sistemas están afectados y qué consecuencias puede tener.

Contención: se intenta limitar el incidente para evitar que continúe extendiéndose o causando daños.

Erradicación: se elimina la causa del problema, por ejemplo un malware o la vulnerabilidad que permitió el ataque.

Recuperación: se vuelven a poner en funcionamiento los sistemas afectados de manera segura y se comprueba que todo funciona correctamente.

Aprendizaje: después del incidente se revisa lo ocurrido para detectar errores y mejorar las medidas de seguridad. Esta parte es importante porque permite evitar que el mismo problema vuelva a repetirse.

Otros conceptos

Indicadores de compromiso (IoC): señales o datos que pueden indicar que un sistema ha sido comprometido. Pueden ser, por ejemplo, archivos sospechosos, procesos extraños, modificaciones en registros o direcciones relacionadas con una actividad maliciosa.

Estrategia proactiva: forma de trabajar que intenta detectar riesgos antes de que se produzca un incidente, en lugar de esperar a que el problema aparezca.

Análisis forense: proceso mediante el cual se recogen, conservan y estudian evidencias digitales para averiguar qué ocurrió y cómo se produjo un incidente.

El ENS también contempla la prevención, detección y respuesta ante incidentes como parte del proceso de seguridad.

Fuentes

INCIBE – Guía nacional de notificación y gestión de ciberincidentes

CCN – Indicadores de compromiso y análisis de intrusiones

BOE – Esquema Nacional de Seguridad

Detección → Análisis → Contención → Erradicación → Recuperación → Aprendizaje

4. Herramientas y tecnologías de aplicación.

Las herramientas de seguridad sirven para controlar las comunicaciones, detectar actividades sospechosas y evitar que programas maliciosos o accesos no autorizados puedan comprometer un sistema.

Entre las herramientas más habituales encontramos las siguientes:

Cortafuegos: controla las conexiones que entran y salen de un equipo o una red y permite bloquear aquellas que no cumplen las reglas establecidas.

IDS (Intrusion Detection System): sistema que analiza la actividad y detecta posibles intrusiones o comportamientos sospechosos. Su función principal es avisar.

IPS (Intrusion Prevention System): además de detectar actividades sospechosas, puede actuar para bloquearlas o impedir que continúen.

Antivirus: programa destinado principalmente a detectar, bloquear y eliminar virus y otros programas maliciosos.

Antimalware: tiene una función más amplia y busca detectar diferentes tipos de malware, como troyanos, spyware, ransomware o virus.

Tipos de cortafuegos

Cortafuegos basado en red: controla el tráfico que circula entre diferentes redes y puede proteger varios dispositivos al mismo tiempo.

Cortafuegos basado en host: está instalado directamente en un equipo y controla las conexiones de ese dispositivo concreto.

Los cortafuegos, IDS e IPS forman parte de las herramientas de protección contempladas en las guías de seguridad del Centro Criptológico Nacional.

Fuentes

CCN – Guías de Seguridad CCN-STIC

INCIBE – Instituto Nacional de Ciberseguridad

5. Normativa y buenas prácticas de uso.

Las normas de seguridad establecen cómo se deben proteger los sistemas y los datos. Entre las más importantes en este ámbito encontramos el **RGPD, la ISO/IEC 27001 y el ENS**.

La seguridad informática también tiene una parte relacionada con las normas y la forma correcta de tratar la información. No todo consiste en instalar programas de protección. También hay que saber qué datos se pueden utilizar, quién puede acceder a ellos y cómo deben protegerse.

Reglamento General de Protección de Datos (RGPD): normativa europea que establece cómo deben tratarse los datos personales y qué derechos tienen las personas sobre ellos. También obliga a aplicar medidas de seguridad adecuadas al riesgo que pueda existir para esos datos.

ISO/IEC 27001: norma internacional que establece los requisitos para crear, mantener y mejorar un sistema de gestión de la seguridad de la información. Su objetivo es ayudar a las organizaciones a gestionar los riesgos relacionados con la información.

Esquema Nacional de Seguridad (ENS): marco establecido en España para proteger la información y los servicios utilizados por las administraciones públicas. El ENS se basa, entre otros principios, en la prevención, detección y respuesta, la gestión de riesgos y la vigilancia continua.

Otros conceptos

Datos sensibles: son datos personales que necesitan una protección especial por el impacto que puede tener su tratamiento sobre los derechos y libertades de una persona. El RGPD incluye, entre otros, datos relativos a la salud, datos genéticos y biométricos, origen étnico o racial, opiniones políticas, religión, vida sexual u orientación sexual y afiliación sindical.

Políticas de acceso: normas que determinan quién puede acceder a un sistema, a qué información puede entrar y qué acciones tiene permitidas.

Ciclo de vida de la información: conjunto de etapas por las que pasa la información desde que se crea o se obtiene hasta que se almacena, utiliza, comparte y finalmente se elimina.

Diagnóstico de fallos: proceso de buscar el origen de un problema o error para poder solucionarlo correctamente.

Propuestas de mejora: cambios o medidas que se plantean para corregir problemas y aumentar la seguridad o el funcionamiento de un sistema.

Registro de incidencias: documento o sistema donde se anotan los incidentes que ocurren, junto con información sobre lo sucedido y las actuaciones realizadas.

Fuentes

AEPD – Conceptos básicos de protección de datos

AEPD – Seguridad de los tratamientos

ISO – ISO/IEC 27001

BOE – Real Decreto 311/2022, Esquema Nacional de Seguridad